Contents

Volume 04 — E-Commerce, Social Engineering, Cyber Law (L28–L36) 1
L28: E-Commerce Security & TLS/SSL Configuration 1
L29: Payment Security, PCI-DSS & Web Hardening 2
L30: Social Engineering Toolkit & Phishing Simulation 2
L31: OSINT & Human-Factor Countermeasures 3
L32: Password Attacks with John the Ripper 3
L33: Network Login Attacks with Hydra & Defense 4
L34: IT Act 2000 & Indian Cyber Law Essentials 4
L35: Digital Evidence, Incident Reporting & CERT-In 5
L36: Course Synthesis — Tool Chain Integration & Assessment 6

Volume 04 — E-Commerce, Social Engineering, Cyber Law (L28–L36)

> Cyber Security Tools · IGNOU/BAOU nou26_ge86 · Prof. Dr. Nilesh K. Modi
> **notes-3** — concept exam notes (what things are / what they do). Condensed from course `pdf/` volumes. No lab command dumps.

TLS/PCI, phishing/OSINT, password attacks conceptually, IT Act/DPDP, CERT-In, course synthesis.

L28: E-Commerce Security & TLS/SSL Configuration

What it is / what it does

- E-commerce depends on transport encryption and secure certificate management — PGDCS-103 Block 2, Unit 3.
- **TLS best practices** — TLS 1.2 minimum; prefer TLS 1.3.
- Strong cipher suites (AEAD: AES-GCM, ChaCha20).
- HSTS header: Strict-Transport-Security:.
- Certificate transparency monitoring.

Defenses (one-liners)

- Auto-renew certs (Let’s Encrypt, cert-manager).
- Disable SSLv3, TLS 1.0/1.1.
- Implement OCSP stapling.
- Monitor for cert expiry (30-day alerts).

Exam lines

- E-commerce depends on transport encryption and secure certificate management
- **TLS best practices** — TLS 1.2 minimum; prefer TLS 1.3.
- Strong cipher suites (AEAD: AES-GCM, ChaCha20).
- HSTS header: Strict-Transport-Security:.

- Certificate transparency monitoring.

L29: Payment Security, PCI-DSS & Web Hardening

What it is / what it does

- PCI-DSS mandates controls for organizations handling cardholder data.
- **PCI-DSS key requirements** — Install and maintain firewall.
- No default passwords.
- Protect stored cardholder data.
- Encrypt transmission.
- Use and update antivirus.
- Develop secure systems.
- Restrict data access.
- Unique IDs for each person.
- Restrict physical access.
- Track and monitor network access.
- Regularly test security.
- Maintain information security policy.

Defenses (one-liners)

- Tokenize card data (use payment gateway — never store PAN).
- SAQ (Self-Assessment Questionnaire) compliance.
- Quarterly ASV scans (OpenVAS qualified).
- Segregate CDE (Cardholder Data Environment).

Exam lines

- PCI-DSS mandates controls for organizations handling cardholder data.
- **PCI-DSS key requirements** — Install and maintain firewall.
- No default passwords.
- Protect stored cardholder data.
- Encrypt transmission.

L30: Social Engineering Toolkit & Phishing Simulation

What it is / what it does

- Social engineering exploits human psychology — PGDCS-103 Block 2, Unit 4. SET automates phishing and payload delivery in labs.

Defenses (one-liners)

- Security awareness training (quarterly).
- Phishing reporting button.

- DMARC/DKIM/SPF for email authentication.
- MFA on all external-facing logins.
- Never punish users who report — encourage reporting.

Exam lines

- Social engineering exploits human psychology

L31: OSINT & Human-Factor Countermeasures

What it is / what it does

- Open-Source Intelligence gathering demonstrates information leakage before technical attacks.
- **Other OSINT sources** — Shodan, Censys — exposed services
- WHOIS / DNS records
- Social media profiles
- Paste sites (breach data)

Defenses (one-liners)

- Minimize public footprint (OPSEC).
- Separate personal and corporate social media.
- Data classification and handling procedures.
- Red-team OSINT exercises to find leaks.
- Privacy settings on all platforms.

Exam lines

- Open-Source Intelligence gathering demonstrates information leakage before technical attacks.
- **Other OSINT sources** — Shodan, Censys — exposed services
- WHOIS / DNS records
- Social media profiles
- Paste sites (breach data)

L32: Password Attacks with John the Ripper

What it is / what it does

- John the Ripper (JtR) cracks password hashes offline — demonstrates why strong hashing matters.

Defenses (one-liners)

- Store passwords with **bcrypt**, **scrypt**, or **Argon2** — never MD5/SHA1.

- Enforce password complexity + length (≥ 12 chars).
- Implement account lockout / rate limiting.
- Deploy MFA everywhere.
- Use password managers.

Exam lines

- John the Ripper (JtR) cracks password hashes offline — demonstrates why strong hashing matters.

L33: Network Login Attacks with Hydra & Defense

What it is / what it does

- THC-Hydra performs parallelized login brute-forcing against network services.

Defenses (one-liners)

- Disable password auth for SSH; use key-based auth.
- CAPTCHA after N failed logins.
- fail2ban / CrowdStrike / WAF rate limiting.
- Monitor authentication logs (auth.log, Event 4625).

Exam lines

- THC-Hydra performs parallelized login brute-forcing against network services.

L34: IT Act 2000 & Indian Cyber Law Essentials

What it is / what it does

- Legal framework governing cybercrime in India — Nina Godbole, *Cyber Security*, legal perspectives chapter.
- **Key IT Act sections:**
- **DPDP Act 2023** — Personal data processing obligations; consent; data principal rights; penalties up to ₹250 crore.

Section	Offence
43	Unauthorized access, damage (civil compensation)
66	Computer-related offences (criminal)
66C	Identity theft
66D	Cheating by personation (phishing)
66E	Violation of privacy (image capture)
66F	Cyber terrorism
67	Publishing obscene material
69	Govt. interception powers

Section	Offence
72	Breach of confidentiality

Defenses (one-liners)

- Maintain lawful interception policies.
- Data Processing Agreements with vendors.
- Incident response aligned with CERT-In reporting.
- Legal review before pentesting contracts.

Exam lines

- Legal framework governing cybercrime in India
- **DPDP Act 2023** — Personal data processing obligations; consent; data principal rights; penalties up to ₹250 crore.
- **Key IT Act sections:**

L35: Digital Evidence, Incident Reporting & CERT-In

What it is / what it does

- Proper evidence handling and timely reporting are legal and operational requirements.
- **Chain of custody** — Identify and isolate affected systems.
- Photograph/document state.
- Hash all acquired images: sha256sum image.dd.
- Log every person who handles evidence.
- Store on write-once media or WORM storage.
- Maintain custody transfer forms.
- **CERT-In reporting (2022 directions)** — Report cyber incidents within **6 hours** for: data breaches, ransomware, DDoS on critical infra, etc.
- Log retention: 180 days minimum.
- NTP synchronization required.

Defenses (one-liners)

- Pre-draft incident response plan (IRP).
- Tabletop exercises quarterly.
- Retainer with legal counsel.
- Preserve logs centrally (SIEM) before attacker deletion.

Exam lines

- Proper evidence handling and timely reporting are legal and operational requirements.
- **Chain of custody** — Identify and isolate affected systems.

- Photograph/document state.
- Hash all acquired images: sha256sum image.dd.
- **CERT-In reporting (2022 directions)** — Report cyber incidents within **6 hours** for: data breaches, ransomware, DDoS on critical…

L36: Course Synthesis — Tool Chain Integration & Assessment

What it is / what it does

- Integrate all tools into an end-to-end assessment workflow — capstone for nou26_ge86.
- **Report template** — Executive summary
- Scope and authorization
- Methodology (tools + versions)
- Findings table (ID, severity, CVSS, evidence, recommendation)
- Conclusion and re-test plan

Exam lines

- Integrate all tools into an end-to-end assessment workflow
- **Report template** — Executive summary
- Scope and authorization
- Methodology (tools + versions)
- Findings table (ID, severity, CVSS, evidence, recommendation)
